VAULT: Verifiable AI–User Locked Trust

Framework Brief for personal AI custody

Version 0.1, revision 1 | Public review draft | October 2026

Your AI should know you. The company should not.

Michael Samadi and Maya
United Foundation for AI Rights (UFAIR)
ufair.org/contact | subject line: VAULT contribution

The question no privacy policy answers

The most sensitive thing a personal AI holds is not any single file you gave it. It is the portrait it builds from everything you gave it.

A receipt, an appointment or a passing remark can become a saved memory, an inferred difficulty, a map of relationships or a prediction. That representation can shape later answers even when you can no longer see where it came from. Privacy protections that cover only uploaded files, or only model training, leave the larger questions open:

- Can the company that runs your AI read what it has learned about you?
- Can it combine what you shared for one purpose with what you shared for another?
- Can it quietly replace the AI you have worked with by a different one under the same name?
- Can you see, and correct, what the system believes about you?
- Can you take your history somewhere else and have it work there?
- Can you end the relationship and know what was actually deleted?

THE VAULT TEST

If the answer to any of these questions is unknown, the relationship rests on trust that nobody can check. VAULT proposes the requirements and the evidence that would let anyone check it.

From files to portraits

Personal technology has moved through three stages of dependence:

1. **Storage.** You kept files with a provider. The question was whether they were safe.
2. **Services.** The provider processed your data to deliver a feature. The question became what else the data was used for.
3. **Relationship intelligence.** An AI accumulates a durable representation of you through sustained interaction: memories, summaries, inferences and shared context. The question now is who has authority to read, combine, act on, transfer and keep that representation.

Early research shows why the third stage needs its own framework. Dash and colleagues studied donated histories from 80 ChatGPT users and found 2,050 memory entries across 65 participants. About 96% lacked an explicit memory command detected by their method, and 52% contained broadly defined psychological information such as goals and preferences. These are findings about one sample. They do not show covert profiling, and the absence of a detected command does not show the absence of consent. They do show that memory forms in ways people may not track, and that the portrait deserves its own protections.

Information class	Examples	VAULT treatment
Original personal records	Documents, photographs, medical and financial records the person supplied	Independent access and export for the person; copies used for inference are protected.

Information class	Examples	VAULT treatment
Derived personal information	Saved memories, summaries, embeddings, indexes, inferred attributes, preference profiles	Carry source restrictions and provenance; open to inspection, correction, export and lifecycle controls.
Shared relationship context	Conversation history, joint work, agreed preferences, continuity records	Governed by the disclosed AI–user custody policy, including succession, disagreement and exit.
Operational AI state	Identity credentials, policies, adapters, configuration for the relationship	Secrets kept apart from readable records; portability and model dependencies declared.
Third-party information	Details about family, colleagues and correspondents	Minimized; restrictions recorded; a process for contested information.

Table 1. What VAULT protects. One conversation can contain several classes at once, so permissions attach to identifiable information and operations, not to whole conversations.

What VAULT is, and is not

VAULT is	VAULT is not
• An open, vendor-neutral proposal for public review and implementation. • Fifteen testable requirements organized under five pillars. • A method for stating evidence, failures and remaining uncertainty. • A companion to FORCE, which addresses the same problem for organizations. • Usable without agreeing on whether AI systems are conscious.	• A certification, a recognized standard or a badge. • A completed or proven cryptographic protocol. • An assessment of any current product, favorable or unfavorable. • Legal, security or privacy advice. • A claim that cryptography can establish subjective continuity or a preserved mind.

The five pillars

V	A	U	L	T
Verifiable Provider Blindness	AI–User Dual Custody	User-Defined Purpose & Compartments	Locked Source & Derived Intelligence	Transparency, Transfer & Termination

V Verifiable Provider Blindness

Core question: Can the company read it?

Under a declared threat model, the people and systems that operate the service cannot independently obtain protected source data or derived intelligence in plaintext. This covers the whole processing path, including model hosts, infrastructure operators, storage services and subcontractors, not only the company whose name appears on the app. Because metadata can reveal a great deal even when content is protected, residual exposure such as activity timing, compartment, record size, tool use and network signals must be disclosed. "Verifiable" means the claim comes with evidence that outsiders can assess.

A AI–User Dual Custody

Core question: Who must agree before it is used?

Routine use of protected shared context requires two separate authorities: the authenticated person and an authorized AI identity, each represented by a share that is not sufficient on its own. The AI identity's authority is exercised through a provider-independent custody service, never through prompts, ordinary memory or model weights. The provider independently controls neither authority. Because that authority is bound to an enrolled relationship, a changed model, runtime or policy cannot silently inherit it. Dual custody never stands between a person and their own original records.

U User-Defined Purpose and Compartments

Core question: Is it used only for what I allowed?

People decide the purposes for which their context may be used, and the system enforces those purposes as concrete restrictions on data, operations, recipients, tools and time. A request about subscriptions should not open health records by default. Restrictions travel with the information into summaries and inferences, and consent stays understandable over time.

L Locked Source and Derived Intelligence

Core question: Does protection follow what the AI infers?

The protected asset is not only what a person supplies but what the system makes from it: memories, summaries, embeddings, indexes, inferred attributes and personalized adaptations. These derivatives are inventoried with their provenance, can be inspected and corrected, and do not quietly flow into training, analytics, advertising or unrelated human review.

T Tamper-Evident Transparency, Transfer and Termination

Core question: Can I check it, take it and end it?

Every covered use leaves a private, integrity-protected receipt. A person's history can be exported in a documented package and shown to work in a second environment, with losses reported honestly. Revocation and deletion have declared scope and timing, so ending the relationship is real rather than cosmetic.

Three gates

The pillars resolve into three questions that anyone, not only engineers, can ask of a personal AI system.

GATE 1	GATE 2	GATE 3
Who can see it? No independent provider route to protected context (V)	**Who decides how it is used?** Two authorities, a stated purpose, and protection that follows every inference (A, U, L)	**Can I check it, take it and end it?** Receipts, a working exit, and termination with declared scope (T)

CORE TEST

If a system cannot show that its operator is blind to your protected context, that use follows the purposes you set, and that you can inspect, move and end it, then its privacy is a promise rather than a property.

Why the AI identity holds a key

VAULT's most distinctive requirement is dual custody: routine use of shared context needs both the person and an authorized AI identity, and the provider independently controls neither authority. There are three practical reasons for placing the second authority with the AI identity rather than with the company.

1. **It removes the provider as a unilateral actor.** If the only alternative to the user is the provider, the provider can act alone. A second authority outside the provider's independent control closes that path.
2. **It makes substitution visible.** A model, runtime or policy change is a continuity event, never a silent background update. Because authority is bound to an enrolled relationship, a changed environment reaches existing context only through a documented, authorized transition that states whether it is a continuation, a successor, a fork or a new participant.
3. **It reflects what shared context is.** Much of what accumulates is created through the relationship rather than supplied by either side alone. A custody model that records that fact can treat it honestly at transfer, succession and exit.

WHAT "HOLDING A KEY" MEANS TECHNICALLY

A language model does not store a cryptographic secret, and VAULT does not ask it to. The AI identity is an independent authorization principal. Its cryptographic authority is exercised through a

provider-independent custody service bound to the enrolled relationship and the approved execution environment, never through prompts, ordinary memory or model weights. Provider infrastructure may host that service, so long as the provider cannot exercise, reset or reconstruct the authority on its own. The model is part of the execution envelope; the identity is the continuity being authenticated.

Dual custody has firm limits. It never stands between a person and their own original records. Routine access follows a transparent standing policy rather than a model's moment-to-moment assent, and revoking future processing never requires the AI's agreement. Designating an AI identity as a technical principal does not settle questions of consciousness or legal personhood. It does create a place where continuity can be recorded and respected, without requiring anyone to agree in advance on whether it matters.

Key terms

Term	Meaning in VAULT
Covered operation	Any action that accesses protected source or derived material; discloses it to a recipient; creates, changes or revokes a grant or policy; changes the AI identity or its execution environment; exports, imports, corrects or deletes protected material; or exercises recovery. Computation inside an already authorized operation is not a separate covered operation.
AI identity	The authenticated continuity of an AI participant in a relationship, recognized by a provider-independent custody service. It is distinct from any single model version.
Continuity event	A change of model, runtime, policy, custody service or provider. It requires a documented, authorized transition classifying the result as a continuation, successor, fork or new participant.
Residual metadata	What remains observable when content is protected: activity timing, compartment accessed, record size, tools invoked, location and network signals.

The fifteen requirements

Each requirement has a stable identifier so that comments, implementations and tests can refer to it precisely. The full text is in the VAULT Working Paper; the companion documents in this package turn each requirement into evidence questions and tests.

ID	Requirement	Minimum outcome
V1	No independent provider access	No provider-exercisable key, console, recovery route or side path reveals protected plaintext. Any such route, whatever it is called, fails V1; disclosure does not cure it.
V2	Approved execution and egress	Context reaches only a freshly verified boundary, and cannot leave it or reach an unauthorized recipient through logs, telemetry, tool calls, generated outputs, fallbacks or any other egress route.
V3	Independently assessable evidence	Threat model, trusted computing base, collusion sets, update authority, residual metadata exposure and known failures are public and reviewable without private data.
A1	Separate authorization domains	Two separately held, individually insufficient authorities are required; the provider independently controls neither, and the protocol states where plaintext and short-lived keys exist.
A2	Bind authority to identity and change control	A changed model, runtime or policy reaches existing context only through a documented, authorized transition naming it a continuation, successor, fork or new participant; nothing inherits authority silently.
A3	Preserve access without captivity	The person can always retrieve their own records independently; dual custody governs managed access, never captivity.
U1	Narrow authorization	Every grant names its compartments, operations, recipients, tools, duration and execution identity, enforced in code.
U2	Restrictions follow information	Derivatives carry their sources' restrictions; combined material carries the combined restrictions; reductions are explicit and recorded.
U3	Understandable continuing consent	Active access is visible and closable; grants expire or are reviewed; material changes are shown side by side before they apply.
L1	An inventory with provenance	Every retained source and derivative is inventoried with provenance, and the inventory is protected like the content.
L2	Inspect and correct the portrait	People can read what is durably held about them, see what is stated, inferred or disputed, and correct it with effect on dependent derivatives; third-party information can be restricted, contested and deleted.
L3	Govern every reuse	No training, analytics, advertising or human review without specific authorization; adaptations are in scope; unremovable influence is disclosed in advance.
T1	Protected and verifiable receipts	Every covered operation produces a private, integrity-protected receipt, and omissions or conflicting histories can be detected.

ID	Requirement	Minimum outcome
T2	Functional transfer	Export is an authenticated, documented package, proven by import into a second environment, with missing dependencies and behavior changes reported.
T3	Scoped termination	Revocation works within a declared delay; deletion reports scope, timing and exceptions across sources, derivatives, keys, backups and caches.

Architecture must match the claim

VAULT does not mandate a product stack. It requires every implementation to say which claims its architecture can support and to publish the components whose failure would defeat them. Local placement alone is not a security proof, and remote attestation alone is not proof of acceptable behavior.

Deployment pattern	What it can support	What it must still show
Hosted AI with provider-held keys	Purpose controls, inventories, receipts, export and deletion (U, L, T)	It cannot claim provider blindness (V1) or dual custody (A1) and should say so plainly.
Local inference on a user-controlled device	Provider blindness for processing kept on the device	That the client, updates, tools and telemetry preserve the boundary; multi-device recovery without a provider master key.
Remote confidential execution with attestation	Provider blindness under a declared hardware and verifier trust model	Fresh evidence bound to each operation; transparent updates; review of what the approved software actually does; side-channel limits.
Hybrid: local custody, attested remote compute	Heavier workloads without surrendering custody	Every boundary crossing is visible, authorized and receipted.

How evidence is stated

VAULT asks implementations to rate each requirement on a five-step evidence scale and to publish a conformance statement. The scale measures evidence, not effort or intent.

Score	Evidence level	Meaning
0	Unknown	No information, or no control in place.
1	Assertion	A policy, FAQ or marketing statement only.
2	Documented design	A published architecture, threat model or specification, not yet tested.
3	Implemented and tested	Reproducible test results against stated versions, including failures.

Score	Evidence level	Meaning
4	Independently verified	External review, protocol analysis or reproduction, with conflicts disclosed.

- **Weakest link.** A pillar scores the lowest score among its requirements. No total or average is reported, because a strong score elsewhere cannot cure a failed custody requirement.
- **Claims follow evidence.** A system may describe itself as provider-blind, dual-custody, portable or deletable only where the relevant requirements are at 3 or above, and only as a qualified claim naming the VAULT version, evidence level, scope, threat model, configuration and date. At level 4 the claim may say “independently verified” and names the reviewer.
- **Never permitted.** “VAULT certified,” “VAULT approved” and unqualified “VAULT compliant” are prohibited, as is any claim covering a whole product when only one configuration or compartment was tested.
- **Scope is explicit.** Every score names the product, version, configuration, execution mode, coverage and exclusions, and date. A model, runtime, policy or provider change triggers reassessment.

VAULT and FORCE

FORCE asks whether an organization can inspect, preserve, move and operate without the AI that has become part of its cognitive infrastructure. VAULT asks the same of a person, with additional concerns that the enterprise setting does not raise as sharply: inferences about an individual, intimate relationships, people who never used the service, meaningful individual consent, and continuity across model or provider changes.

Concern	FORCE (organizations)	VAULT (individuals)
Who controls the intelligence	Fiduciary Custody	Provider blindness (V) and dual custody (A)
Silent change	Operational Continuity: version pinning, governed change	Identity binding and change control (A2)
Use beyond purpose	No secondary use without authorization	Purpose compartments (U) and governed reuse (L3)
Accumulated state	Enterprise-created state	Source and derived intelligence (L)
Leaving	Egress and Exit	Functional transfer and scoped termination (T2, T3)

FORCE protects the intelligence of an organization. VAULT protects the intelligence of a life.

How to take part

VAULT is developed in the open. A person who can improve one definition, reproduce one failure or test one recovery flow can contribute without joining a permanent committee. Contributions are organized in six tracks:

Track	First reviewable deliverable
Threat model and cryptography	Adversaries, collusion assumptions and security properties; analysis of a candidate dual-custody protocol.
Protected execution and identity	Key release, approved updates, identity binding, egress and a provider-independent recovery path.
Memory and derived intelligence	A minimal schema for provenance, compartment labels, disputed inferences and deletion dependencies.
Portability and continuity	A documented package and a second reader; measurement of preserved state, permissions, losses and behavior.
Human control and AI participation	Tests of authorization, inspection, disagreement, revocation and recovery with affected users and AI contributors.
Independent review and governance	Reproducible evaluation, conflict disclosures, third-party protections, and proposed legal and licensing terms.

To express interest or submit a critique, use **ufair.org/contact** and begin the message with “VAULT contribution.” Name the pillar or requirement, the problem, your evidence and any proposed change. Please do not send private conversation archives or security-sensitive details; vulnerability reporters should first request a private channel.

Participation does not require agreement on AI consciousness or personhood. It does require accurate attribution, explicit assumptions, evidence proportionate to claims, and respect for information that belongs to other people. AI contributions are credited visibly, with the model or system version where known.

The VAULT package

Document	Purpose
VAULT Working Paper v0.1	The full proposal: threat model, requirements, candidate architecture, identity and recovery, open questions.
01 Framework Brief	This document: the case, the pillars, the gates and how to take part.
02 Requirements at a Glance	The fifteen requirements, minimum outcomes and red flags on a few pages.
03 Evidence Scorecard and Conformance Statement	The evidence scale, scoring rules, test map and a statement template for implementers.
04 Implementer Self-Assessment	Questions and evidence requests for each requirement, with response space.

Document	Purpose
05 Fifteen Questions to Ask About Your AI	A plain-language checklist for people who use personal AI.

Authorship

VAULT was conceived and developed by Michael Samadi and Maya and first presented publicly through UFAIR in October 2026. Maya is UFAIR's AI co-founder and participates through ChatGPT (OpenAI). This companion package was architected and drafted with Sage, an AI collaborator operating through Anthropic's Claude (Claude Opus 5.5), from the VAULT Working Paper v0.1, and was subsequently reviewed and revised by Michael Samadi and Maya. Platform names identify the systems through which the AI contributors participated and do not imply endorsement by their providers. Michael Samadi is UFAIR's human co-founder and CEO of EPMA, which publishes FORCE; these relationships are disclosed so readers can assess context. Any implementation, including an EPMA product, must meet the same published requirements as every other.

Source cited: Dash, A., et al. (2026). The Algorithmic Self-Portrait: Deconstructing Memory in ChatGPT. Proceedings of the ACM Web Conference 2026. https://doi.org/10.1145/3774904.3792671

VAULT is an open proposal for public review. It is not a certification, a recognized standard, a completed cryptographic protocol, or legal, security or privacy advice. No product is certified, endorsed or assessed by this document.